STHIROS
Strategy. Risk. Cyber. AI.



Aligning a manufacturer's IT security with ISO 27001, NIST, and CIS, from scratch

A major manufacturing company engaged Sthiros to build a comprehensive IT security policy framework aligned with industry best practices, from incident response to secure development.

Client	Service	Sector	Geography
A Major Manufacturing Company	**IT & Security SOP Drafting and Modification**	**Manufacturing**	**Global**

The Challenge:

When IT security runs on instinct, not documented policy

This manufacturing company needed a comprehensive IT policy framework aligned with industry best practices, but incident response, access management, cryptography, and secure development all ran without documented standards to govern them.

Incident Management

No incident response playbooks existed for DDoS, phishing, or malware, with no documented classification, escalation, or response workflow.

Access & Identity Management

Password management practices were inadequate with no centralised solution, and no centralised application inventory existed.

Cryptography & Data Protection

Cryptographic practices were undocumented, with no defined standards or key management, and no data protection procedure for classification or disposal.

Vulnerability & Development Security

No vulnerability management procedure existed, and the Secure Software Development Lifecycle was entirely undocumented.

The Solution:

A complete policy suite, built to ISO 27001, NIST, and CIS

Sthiros built a comprehensive IT policy framework spanning incident response, vulnerability management, access control, cryptography, and secure development, aligned to ISO 27001, NIST, and CIS standards.

Every policy was built to be operational, not aspirational, with concrete standards, thresholds, and procedures a team could actually follow.

The Methodology

1

Incident Response Playbooks

Detection, escalation, response, and recovery procedures built for every threat type, from DDoS to phishing to malware.

2

Vulnerability Management Framework

Scanning frequency, risk scoring, patch prioritisation, and tracking established as a standing framework.

3

Access & Password Management Policy

Password complexity, MFA, and privileged access standards documented and centralised across the organisation.

4

Cryptographic Standards & Data Classification

AES-256 and RSA-2048 algorithms, key management, and HSM usage defined, alongside a four-tier data classification scheme.

5

Secure SDLC

Security checkpoints, code review, and SAST/DAST testing built directly into the development lifecycle.

What This Means

Write the playbook before the breach.

One password policy, everywhere.

Turn IP protection into procedure.

Outcomes

6

Policy areas established

Access Control, Data Protection, Incident Response, Cryptography, Cloud Security, and SDLC.

4

Data classification tiers defined

Restricted, Confidential, Internal, and Public, each with handling requirements.

3

Industry standards aligned

ISO 27001, NIST, and CIS frameworks embedded into the policy suite.

4 Months

Engagement duration

From gap assessment through to a complete, audit-ready policy framework.

Get in touch

Is your IT security documented, or just assumed?

Speak to Sthiros about what a structured IT security policy framework can unlock for your organisation.

Connect with Us:
sthiros.com

STHIROS
Strategy. Risk. Cyber. AI.